Attacco a un Dominio Active Directory e Detection con SIEM

1. Introduzione

Il documento descrive la costruzione di un piccolo dominio Active Directory, la sua compromissione a partire da una macchina Kali Linux e la verifica dal SIEM Wazuh.

Parametro	Valore
Obiettivo	Compromettere un dominio AD e verificare la capacità di detection del SIEM
Dominio target	epicode.local
Domain Controller	DC01 — 192.168.56.10 (Windows Server 2022)
SIEM	Wazuh 4.14.8 — 192.168.56.100
Attaccante	Kali Linux — 192.168.56.40
Rete	Host-Only isolata — 192.168.56.0/24

2. Architettura del Laboratorio

Macchina	Ruolo	Sistema operativo	IP
DC01	Domain Controller / DNS	Windows Server 2022	192.168.56.10
DESKTOP-9K1O4BT	Client di dominio	Windows 10 Pro	192.168.56.20
wazuh-server	SIEM	Wazuh (appliance OVA)	192.168.56.100
kali	Attaccante	Kali Linux	192.168.56.40

3. Metodologia

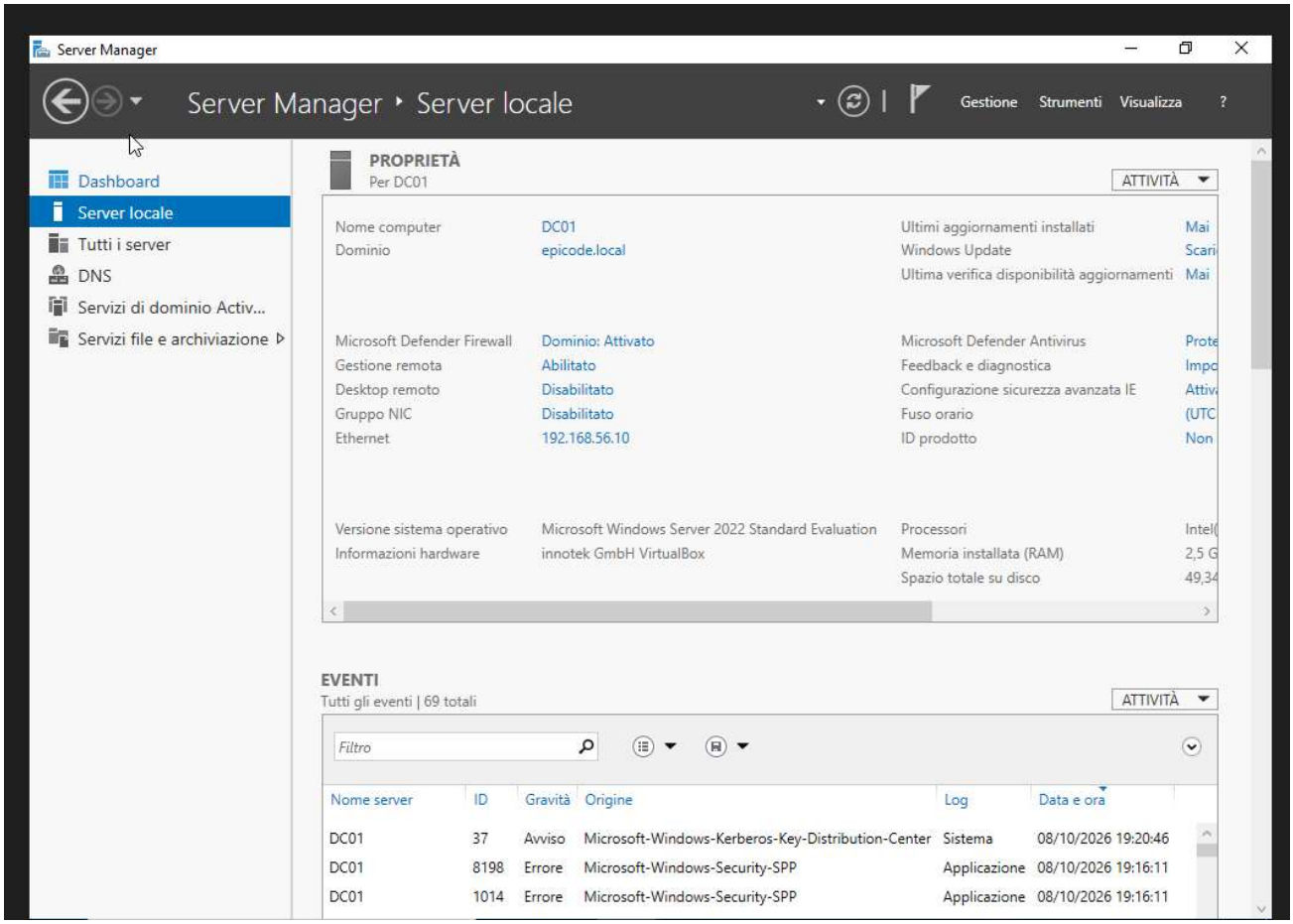
Il progetto è stato condotto in fasi successive:

- Costruzione del dominio Active Directory (Domain Controller, utenti, gruppi, share).
- Aggiunta di un client Windows al dominio e logon di un utente.
- Deploy del SIEM Wazuh e installazione degli agent su DC e client.
- Esecuzione degli attacchi dalla Kali, suddivisi in tre categorie: (1) ricognizione ed enumerazione, (2) attacchi su credenziali / Kerberos, (3) movimento laterale / command execution.
- Verifica, per ciascun attacco, di cosa è stato registrato dal SIEM, correlando gli eventi per orario.

4. Configurazione dell'Ambiente

Domain Controller

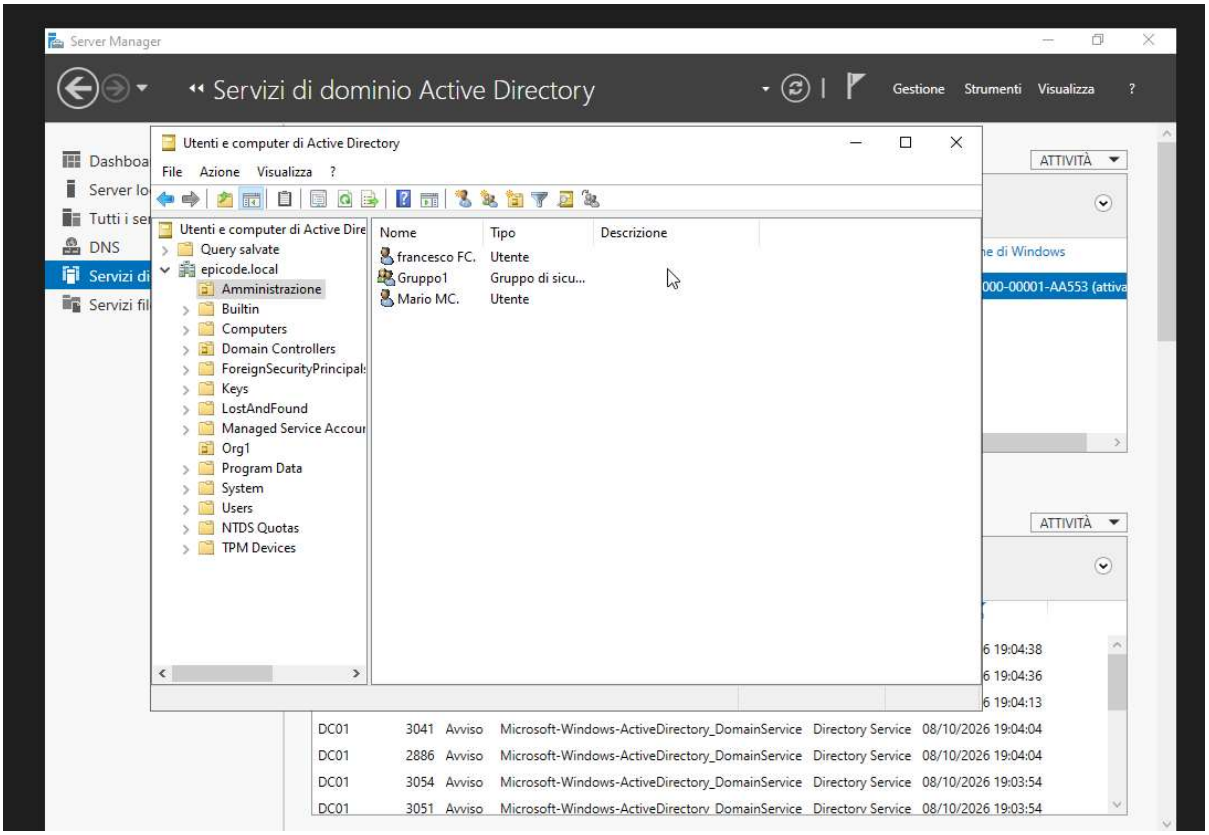
È stato installato Windows Server 2022 e promosso a Domain Controller del nuovo dominio epicode.local, con ruolo DNS integrato. Il server ha indirizzo statico 192.168.56.10.

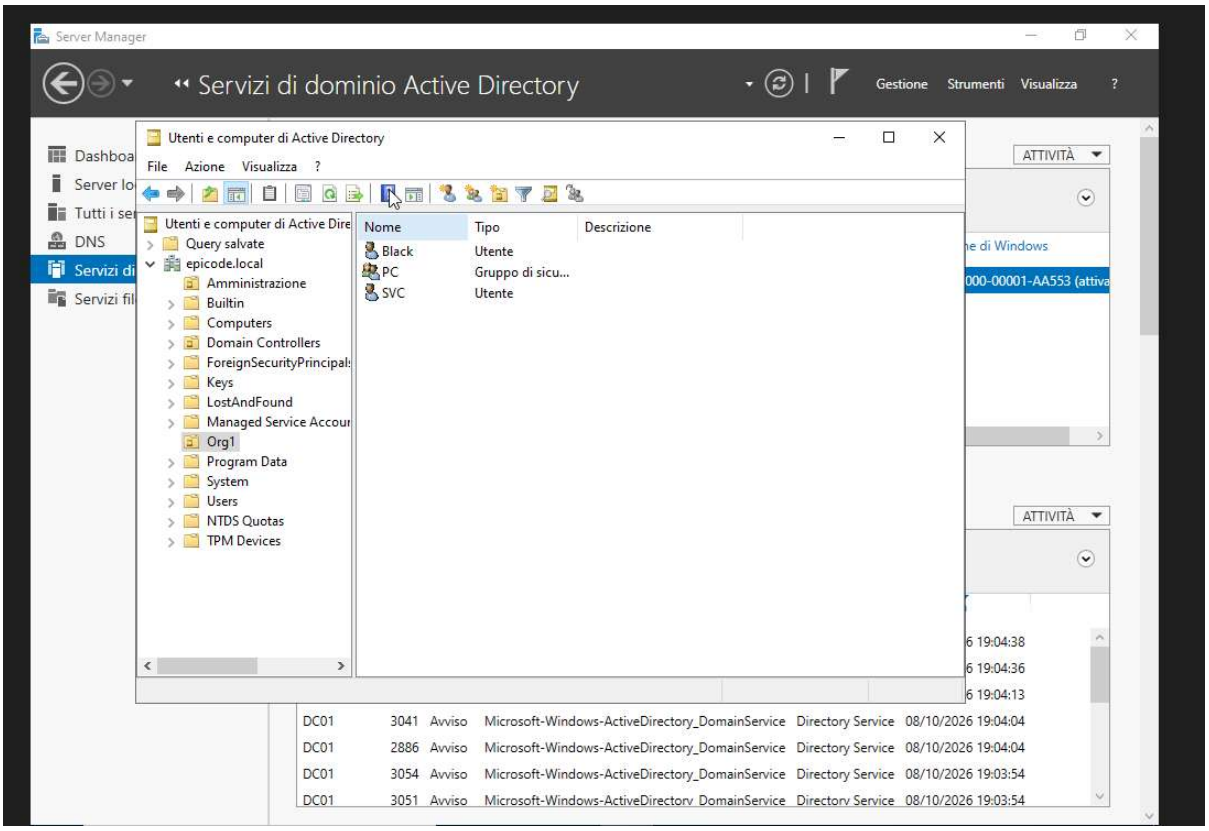


Utenti, gruppi e share

All'interno del dominio sono state create due unità organizzative, Amministrazione e Org1, con i relativi utenti e gruppi di sicurezza.

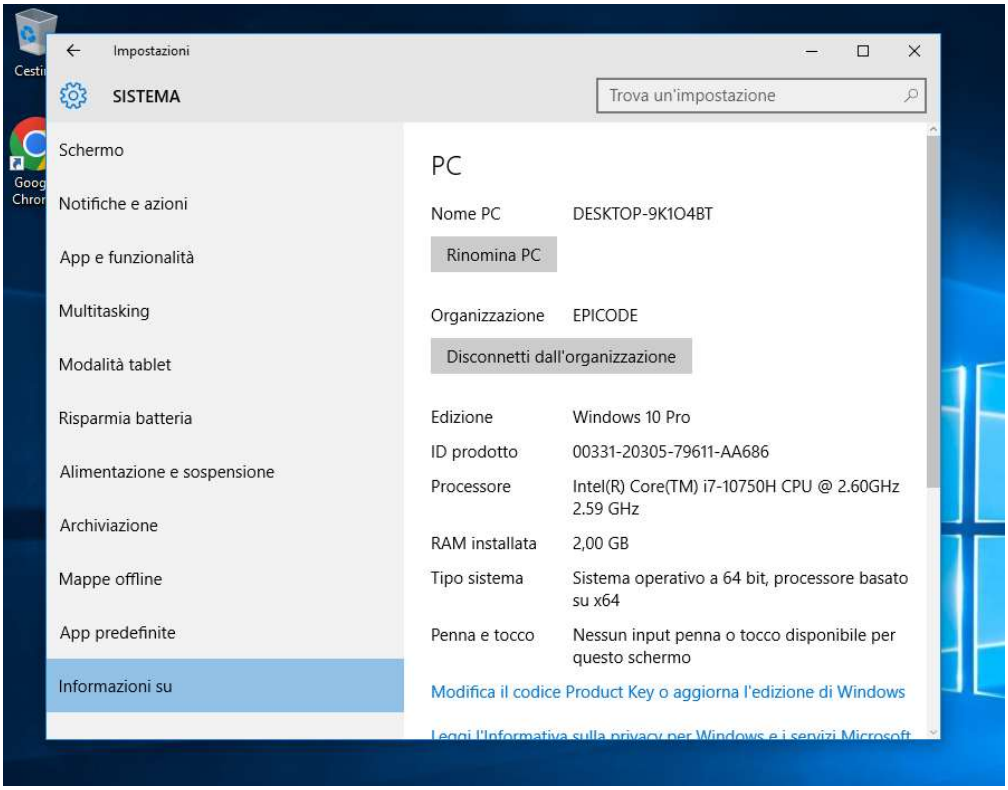
Unità organizzativa	Utenti	Gruppo di sicurezza
Amministrazione	francesco, Mario	Gruppo1
Org1	black, svc	PC


Server Manager
Servizi di dominio Active Directory
Gestione
Strumenti
Visualizza
Utenti e computer di Active Directory
File
Azione
Visualizza
Utenti e computer di Active Dire
Query salvate
epicode.local
Amministrazione
Builtin
Computers
Domain Controllers
ForeignSecurityPrincipals
Keys
LostAndFound
Managed Service Accour
Org1
Program Data
System
Users
NTDS Quotas
TPM Devices
Nome
Tipo
Descrizione
francesco FC.
Utente
Gruppo1
Gruppo di sicu...
Mario MC.
Utente
ATTIVITÀ
DC01 3041 Avviso Microsoft-Windows-ActiveDirectory_DomainService Directory Service 08/10/2026 19:04:04
DC01 2886 Avviso Microsoft-Windows-ActiveDirectory_DomainService Directory Service 08/10/2026 19:04:04
DC01 3054 Avviso Microsoft-Windows-ActiveDirectory_DomainService Directory Service 08/10/2026 19:03:54
DC01 3051 Avviso Microsoft-Windows-ActiveDirectory_DomainService Directory Service 08/10/2026 19:03:54


Server Manager
Servizi di dominio Active Directory
Gestione
Strumenti
Visualizza
Utenti e computer di Active Directory
File
Azione
Visualizza
Utenti e computer di Active Dire
Query salvate
epicode.local
Amministrazione
Builtin
Computers
Domain Controllers
ForeignSecurityPrincipals
Keys
LostAndFound
Managed Service Accour
Org1
Program Data
System
Users
NTDS Quotas
TPM Devices
Nome
Tipo
Descrizione
Black
Utente
PC
Gruppo di sicu...
SVC
Utente
ATTIVITÀ
DC01 3041 Avviso Microsoft-Windows-ActiveDirectory_DomainService Directory Service 08/10/2026 19:04:04
DC01 2886 Avviso Microsoft-Windows-ActiveDirectory_DomainService Directory Service 08/10/2026 19:04:04
DC01 3054 Avviso Microsoft-Windows-ActiveDirectory_DomainService Directory Service 08/10/2026 19:03:54
DC01 3051 Avviso Microsoft-Windows-ActiveDirectory_DomainService Directory Service 08/10/2026 19:03:54

Client di dominio

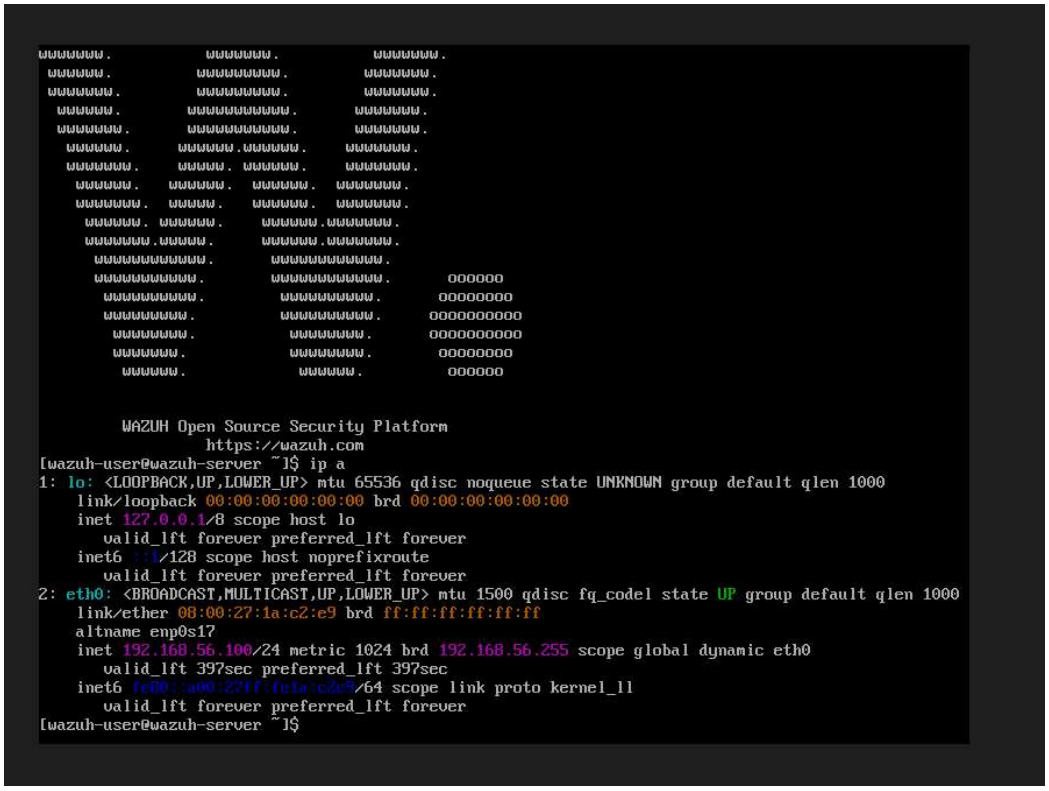
Una macchina Windows 10 Pro (DESKTOP-9K1O4BT, 192.168.56.20) è stata unita al dominio epicode.local, puntando il DNS al Domain Controller. È stato effettuato un logon con l'utente di dominio francesco.

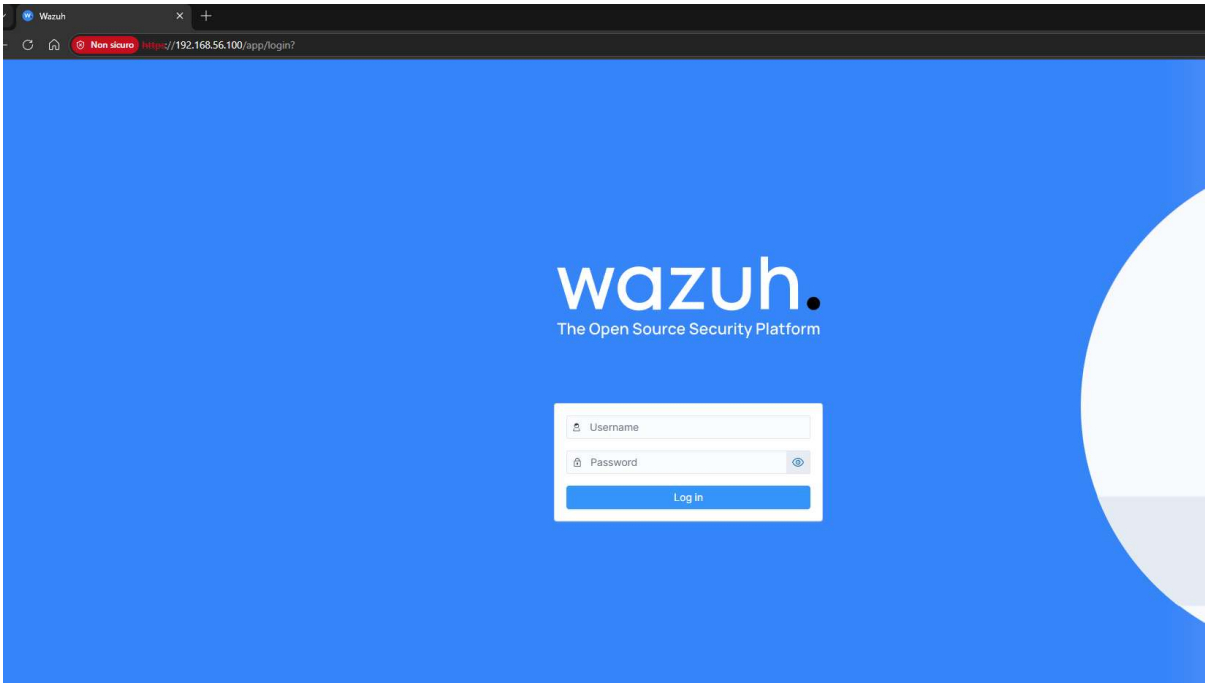


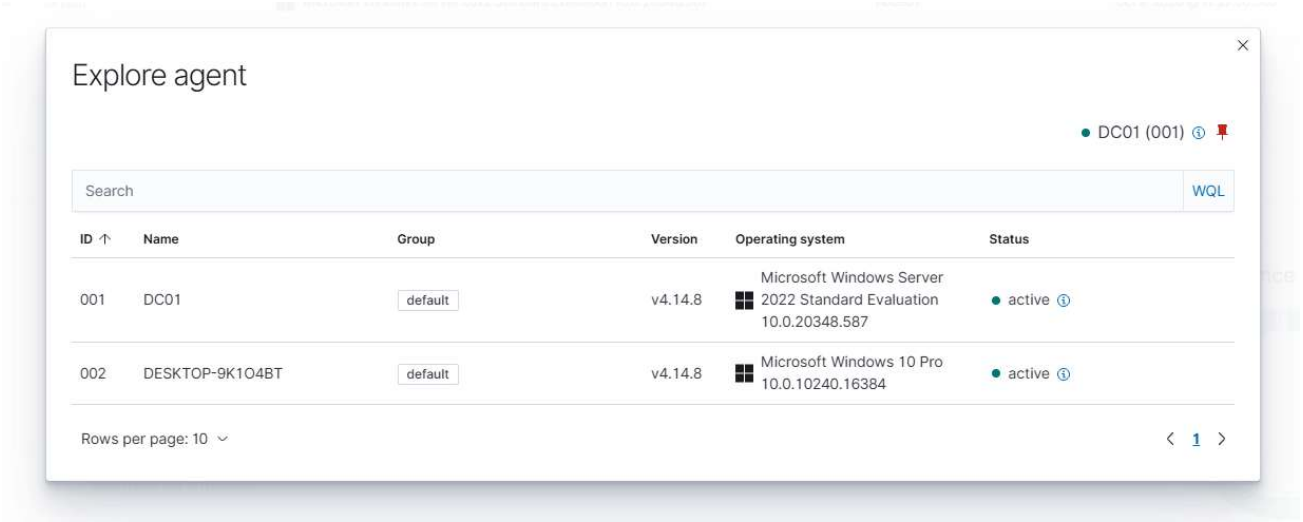


SIEM Wazuh

Il SIEM scelto è Wazuh , con indirizzo 192.168.56.100. Sul Domain Controller e sul client è stato installato l'agent Wazuh, che inoltra al manager i log di sicurezza di Windows.







5. Attacchi e Risultati

Ricognizione ed Enumerazione

Individuazione del Domain Controller ed enumerazione del dominio.

Scansione delle porte del DC con nmap:

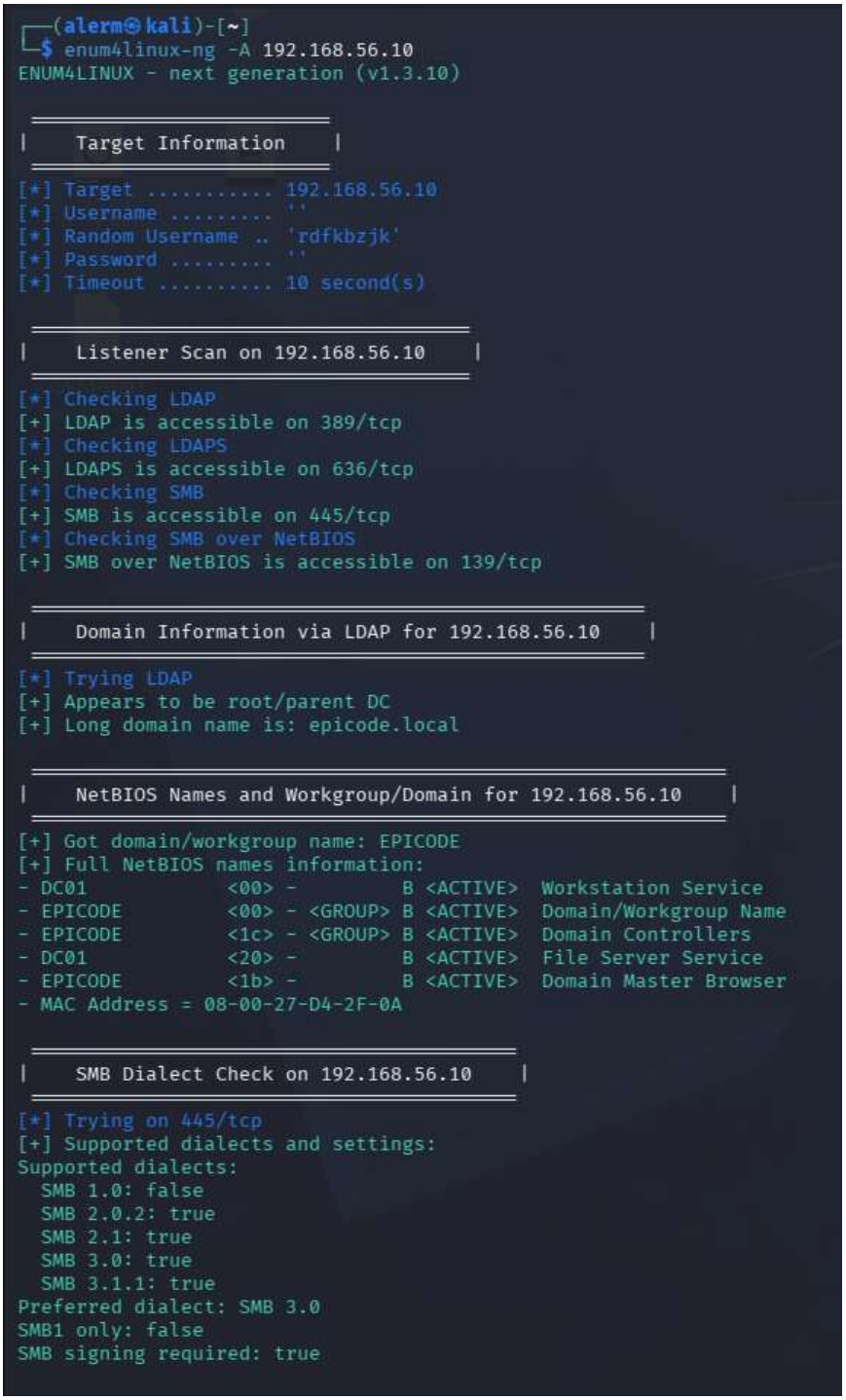
```
┌──(alerm㉿kali)-[~]
└─$ nmap -Pn -sV -p 53,88,135,139,389,445,464,636,3268,3389 192.168.56.10
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-09 17:53 +0200
Nmap scan report for 192.168.56.10
Host is up (0.0029s latency).

PORT     STATE    SERVICE       VERSION
53/tcp   open     domain        Simple DNS Plus
88/tcp   open     kerberos-sec  Microsoft Windows Kerberos (server time: 2026-10-09 15:53:58Z)
135/tcp  open     msrpc         Microsoft Windows RPC
139/tcp  open     netbios-ssn   Microsoft Windows netbios-ssn
389/tcp  open     ldap          Microsoft Windows Active Directory LDAP (Domain: epicode.local, Site: Default-First-Site-Name)
445/tcp  open     microsoft-ds?
464/tcp  open     kpasswd5?
636/tcp  open     tcpwrapped
3268/tcp open     ldap          Microsoft Windows Active Directory LDAP (Domain: epicode.local, Site: Default-First-Site-Name)
3389/tcp filtered ms-wbt-server
MAC Address: 08:00:27:D4:2F:0A (Oracle VirtualBox virtual NIC)
Service Info: Host: DC01; OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 8.77 seconds
```

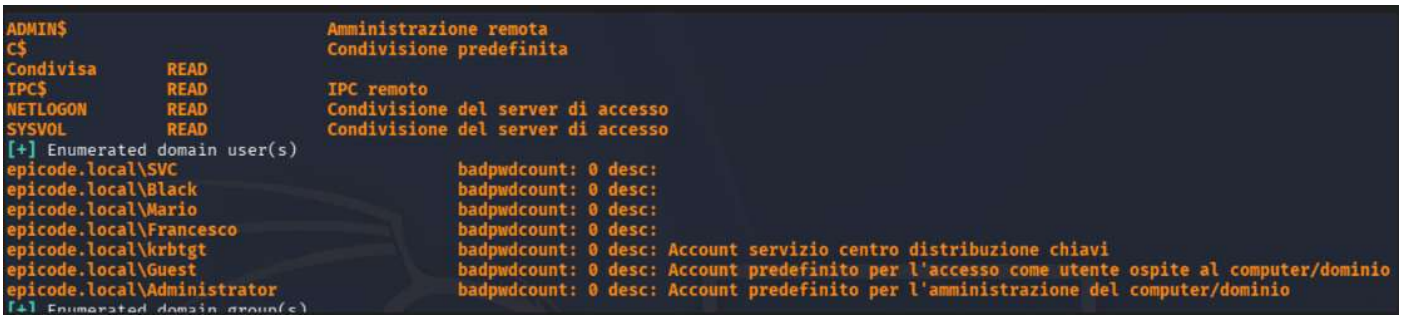
La presenza combinata delle porte 88 (Kerberos), 389/636/3268 (LDAP/Global Catalog) e 53 (DNS) identifica la macchina come Domain Controller del dominio epicode.local.

Enumerazione SMB/LDAP con enum4linux-ng:



Enumerazione autenticata con una credenziale di dominio qualsiasi (francesco) tramite crackmapexec:

```
crackmapexec smb 192.168.56.10 -u francesco -p 'Benvenuto1.' --users --groups --shares
--pass-pol
```

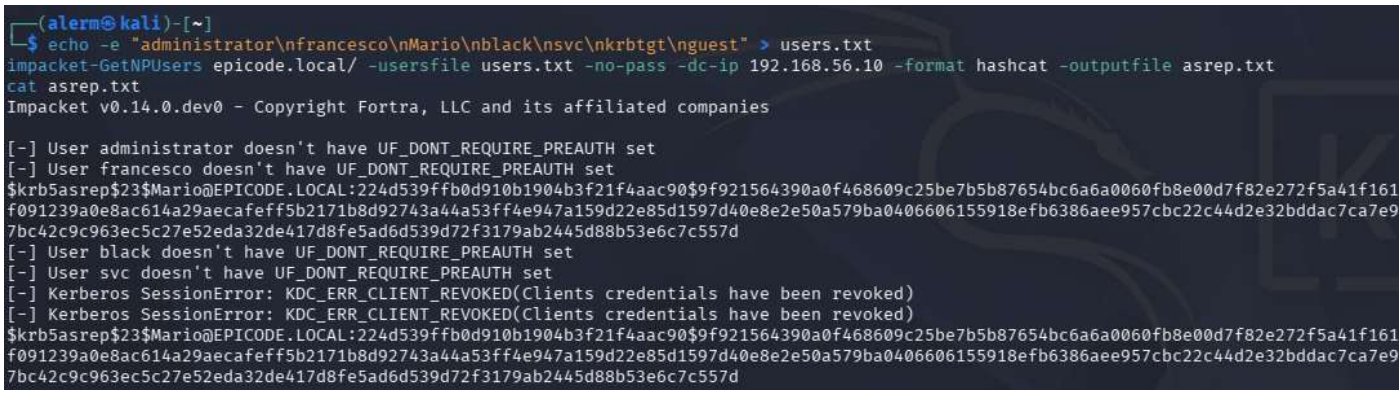


Attacchi su Credenziali / Kerberos

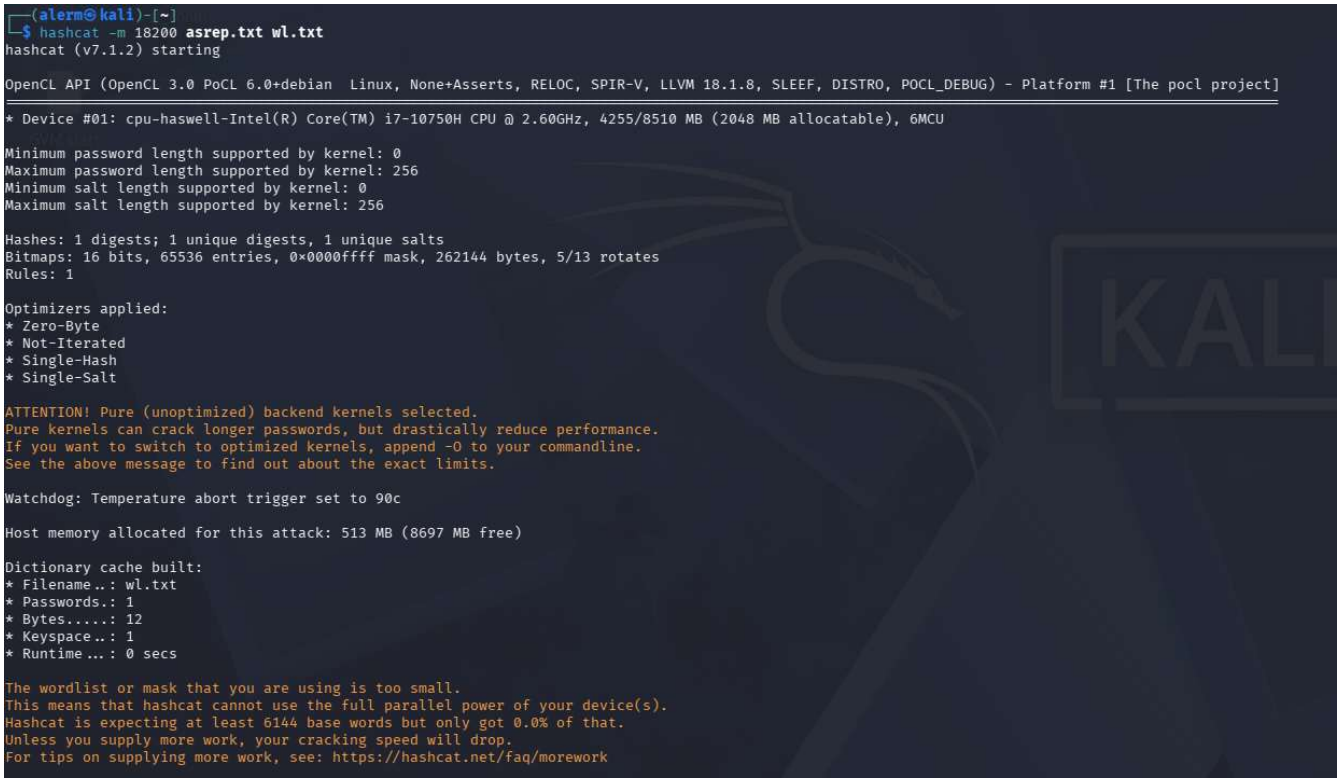
Due attacchi Kerberos classici, che permettono di ottenere credenziali di dominio con nessuna o minima informazione iniziale.

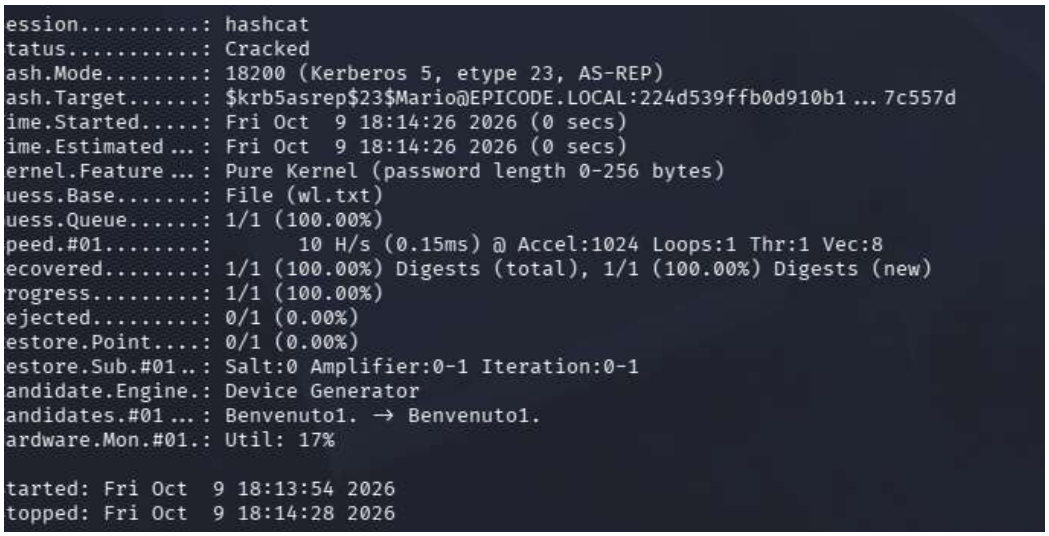
AS-REP Roasting

L'account Mario non richiede la preautenticazione Kerberos: è quindi possibile richiederne il ticket AS-REP e ottenerne l'hash senza alcuna credenziale.



L'hash è stato crackato offline con hashcat (modalità 18200).





Movimento Laterale / Command Execution

Con le credenziali del Domain Admin svc ottenute dal Kerberoasting, sono stati verificati l'accesso amministrativo e l'esecuzione di comandi da remoto.



Il DC risulta Pwn3d! (accesso amministrativo completo). Il client, invece, non è risultato raggiungibile su SMB: il Windows Firewall ha bloccato il movimento laterale verso di esso.

6. Detection sul SIEM (Wazuh)

Per ogni categoria di attacco è stato verificato cosa Wazuh ha registrato.



agent.name	rule.description
DC01	Successful Remote Logon Detected - User:\Francesco - NTLM authentication, possible pass-the-hash attack.

Tabella di correlazione attacco ↔ detection

Cat.	Attacco	Esito	Rilevazione sul SIEM
1	nmap + enum4linux-ng + crackmapexec	DC e dominio enumerati (utenti, gruppi, share, policy)	Logon NTLM/anonimi da Kali — regole 92652/92657; guest fallito — 60122
2	AS-REP Roasting (Mario)	Hash AS-REP estratto e crackato	Event 4768 (preauth 0) raccolto, non allertato di default
2	Kerberoasting (svc)	Hash TGS crackato; svc = Domain Admin	Event 4769 (RC4/0x17) raccolto, non allertato di default
3	crackmapexec / wmiexec (svc)	Accesso admin e command execution sul DC	Logon svc da Kali — regola 92652; Event 7045 / 4688
3	psexec (svc)	Bloccato da Windows Defender	Installazione servizio (Event 7045) registrata

7. Vulnerabilità e Findings

01 — Account di servizio sovra-privilegiato con SPN [CRITICO]

L'account di servizio svc espone un SPN ed è membro di Domain Admins. Il Kerberoasting consente di ottenerne l'hash e, dato che la password è debole, di craccarla offline: il risultato è il controllo completo del dominio a partire da una semplice credenziale utente.

02 — Password deboli e riutilizzate [CRITICO]

Gli account di dominio utilizzano password deboli e identiche tra loro. Questo le rende craccabili offline in pochi secondi e permette, con una sola credenziale ottenuta, di accedere a tutte le risorse (riuso delle credenziali).

03 — Utente senza preautenticazione Kerberos [ALTO]

L'account Mario ha l'opzione “Non richiedere la preautenticazione Kerberos” attiva, esponendolo all'AS-REP Roasting: un attaccante non autenticato può ottenerne l'hash e tentarne il crack offline.

04 — Nessun blocco account (Account Lockout Threshold: None) [MEDIO]

Il dominio non applica alcuna soglia di blocco degli account dopo ripetuti tentativi falliti. Questo abilita attacchi di password spraying e brute force senza il rischio di bloccare gli account bersaglio.